

Day 20 – MITRE ATT&CK Navigator

MITRE ATT&CK Fundamentals

The **MITRE ATT&CK Framework (Adversarial Tactics, Techniques, and Common Knowledge)** is a globally recognized knowledge base that documents real-world attacker behaviors. Instead of focusing on malware families, ATT&CK categorizes **how attackers achieve their objectives**, enabling SOC teams to improve detection engineering, threat hunting, incident response, and security coverage.

Core Concepts

Component	Description
ATT&CK Framework	Knowledge base of real-world adversary behaviors.
ATT&CK Matrix	Organized view of tactics and techniques.
ATT&CK Navigator	Interactive tool used to visualize and assess ATT&CK coverage.
Tactic	Attacker's objective ("What is the goal?").
Technique	Method used to achieve the objective ("How is it done?").
Sub-technique	More specific implementation of a technique.

Why SOC Teams Use MITRE ATT&CK

MITRE ATT&CK provides a common language for defenders to understand attacker behavior and evaluate security controls.

Common Use Cases

- Map SIEM detections to ATT&CK techniques.
- Build and improve detection rules.
- Perform threat hunting based on attacker behaviors.
- Correlate incidents using standardized techniques.
- Identify detection gaps and prioritize improvements.
- Measure overall detection coverage.

Detection Coverage Assessment

Current detection coverage demonstrates a strong focus on **Windows endpoint monitoring**, particularly in **Execution, Persistence, Credential Access, and Defense Evasion**. Existing detections provide good visibility into common attacker behaviors, while **Initial Access, Lateral Movement, Command and Control, and Exfiltration** remain areas for future improvement.

Coverage Summary

Strong Coverage Needs Improvement

Execution	Initial Access
Persistence	Lateral Movement
Credential Access	Collection
Defense Evasion	Command & Control
Basic Discovery	Exfiltration & Impact

Practical Exercise Findings

- Explored the **MITRE ATT&CK Enterprise Matrix** and studied attacker tactics, techniques, and sub-techniques.
 - Mapped previously developed detections—including **PowerShell, Certutil, Registry Run Keys, Scheduled Tasks, and RDP**—to their corresponding ATT&CK techniques using the ATT&CK Navigator.
 - Evaluated current detection coverage, identifying strengths in endpoint visibility while recognizing opportunities to expand into **network-based detections, lateral movement, and command-and-control monitoring**.
 - Assessed detection maturity and learned that **behavioral correlation, threat intelligence enrichment, and continuous tuning** improve detection accuracy and reduce false positives.
-

MITRE ATT&CK Mapping

Activity	ATT&CK Technique
PowerShell Execution	T1059.001 – PowerShell
Certutil Usage	T1218.010 – System Binary Proxy Execution (Certutil)
Brute Force	T1110 – Brute Force
Remote Desktop Login	T1021.001 – Remote Desktop Protocol
Registry Run Keys	T1547.001 – Registry Run Keys / Startup Folder
Scheduled Task	T1053.005 – Scheduled Task/Job
Outbound HTTPS	T1071.001 – Application Layer Protocol: Web Protocols

Investigation Scenario

A multi-stage attack began with **repeated failed logins followed by a successful RDP session**, indicating potential credential compromise. The attacker executed an **encoded**

PowerShell command, used **Certutil** to download a payload, established persistence through **Registry Run Keys** and **Scheduled Tasks**, and communicated with an external host over **HTTPS**, consistent with Command-and-Control activity. Existing detections provided strong coverage for execution and persistence, while additional **network telemetry, behavioral correlation, and threat intelligence** would further improve detection capability.

Detection Engineering Recommendations

- Correlate authentication, process, persistence, and network events into a single investigation.
 - Expand detections for **phishing, WMI, PsExec, DNS beaconing, and data exfiltration**.
 - Integrate firewall, DNS, proxy, and threat intelligence data to improve context.
 - Continuously map detections to ATT&CK to identify coverage gaps and guide future detection development.
-

Detection Maturity

Detection	Maturity
PowerShell	High
Registry Persistence	High
Scheduled Task	High
Certutil	Medium
RDP	Medium
HTTPS Command & Control	Medium

Key Takeaway

MITRE ATT&CK provides a standardized framework for understanding attacker behavior and evaluating defensive capabilities. By mapping detections to ATT&CK techniques, SOC analysts can measure coverage, identify detection gaps, prioritize improvements, and build higher-fidelity detections through behavioral correlation and continuous tuning.